Simplified GDPR Consent Manager

System Validation Report

End-to-end execution of all 41 system test cases from the Test Plan on the running system

#	Name	SRN
1	SUMAN DIDDIMANI	PES1UG24AM409
2	PRADEEP T	PES1UG24AM385
3	VILAS	PES1UG24AM415
4	PRANAAV PRABHAKARAN	PES1UG24AM387

Version	Date	Author	Change Summary
1.0	03-11-2026	Team 6	Report generated from the executed test run (Sprint 3 testing, issue #25)

1. Summary

Item	Value
Test cases executed	41 of 41
Passed	41
Failed	0
Defects found / fixed	3 / 3
Execution date	03-11-2026
Requirements covered	20 FR + 7 SEC + 14 NFR = 41 (100 %)

2. Test environment

Component	Local system test	Deployed system
Front end	React 18 production build (vite preview, port 4174)	Same build served by Express
API	Node 20, Express 4, Prisma 5 (port 4000)	Render web service (free plan, Singapore)
Database	PostgreSQL 16 (gdpr_sys); extra DBs: no-policy, restore target, volume DB (10k users / 500k records)	Neon PostgreSQL (gdpr_prod)
Tools	Python requests + psql (API/DB checks), Playwright Chromium (UI), axe-core 4 (accessibility), k6 0.54 (load)	Chrome DevTools (TLS), UptimeRobot
URL	http://localhost:4174	https://gdpr-consent-manager.onrender.com

Every case was run against the real application code and a real PostgreSQL database - nothing was mocked. Database checks used SQL directly on the tables.

3. Results by test case

TC	Title	Status	Actual result
TC-AUTH-01	User Registration with Unique Email	PASS	HTTP 201; role USER; bcrypt hash cost 12 ($2a$12$); e-mail stored AES-256-GCM encrypted with an HMAC lookup hash.

TC	Title	Status	Actual result
TC-AUTH-02	User Login with Valid Credentials	PASS	HTTP 200; JWT in httpOnly gdpr_session cookie; LOGIN_SUCCEEDED audit entry with UTC time; landing page USER /dashboard, ADMIN /admin, DPO /dpo.
TC-AUTH-03	Logout Ends the Session Immediately	PASS	after logout the browser is on /login, /dashboard redirects to /login, and the old cookie gets HTTP 401 UNAUTHENTICATED.
TC-CONS-01	Display Active Processing Purposes	PASS	all active purposes shown as cards with name, plain-language description and status badge (Not given / Granted / Withdrawn).
TC-CONS-02	Display Currently Published Policy	PASS	title, version 1.0, effective date and the full text are shown.
TC-PURP-01	Administrator Manages Purposes	PASS (via API)	PURP_NEWSLETTER created (201), ANALYTICS deactivated (200) and hidden from the user dashboard at once; PURPOSE_CREATED / PURPOSE_DEACTIVATED audited.
TC-CONS-03	Explicit User Opt-In (Grant Consent)	PASS	201 in about 40 ms; new consent_records row; status Granted; CONSENT_GRANTED audited.
TC-CONS-04	Explicit User Opt-Out (Withdraw Consent)	PASS	new WITHDRAWN row; status Withdrawn; CONSENT_WITHDRAWN audited. Withdrawal is one click (no confirm dialog), by design.
TC-CONS-05	Capture UTC Timestamp & Policy Version	PASS	recorded_at is timestamptz in UTC (API returns ISO-8601 'Z'); policy_version_id equals the published policy.
TC-CONS-06	Reject Invalid Consent Actions	PASS	409 PURPOSE_INACTIVE, 409 CONSENT_UNCHANGED, 409 NO_PUBLISHED_POLICY, 400 for an unknown action; no record written in any case.
TC-HIST-01	Verify Append-Only Storage Model	PASS	4 toggles give exactly 4 rows; an UPDATE on them is rejected by the append-only trigger.
TC-HIST-02	Reverse-Chronological History View	PASS	5 entries, strictly newest first, each with purpose, action and policy version.
TC-POL-01	Create Draft Policy Version	PASS after fix	draft 1.1 saved as DRAFT. Defect D-01 found on first run (a USER could open a draft by id); fixed and re-tested: USER now gets 404.
TC-POL-02	Publish Policy & Supersede Previous	PASS	1.1 PUBLISHED with effective_at = publish time; 1.0 SUPERSEDED; only one published version.
TC-POL-03	Immutability of Published/Superseded Policies	PASS	PATCH on 1.0 and 1.1 returns 409 POLICY_LOCKED; a direct SQL UPDATE is rejected by a trigger.
TC-POL-04	User Notification on Policy Update	PASS	after 2.0 is published the user sees 'Our privacy policy changed to version 2.0' with the change summary and a link to the new policy.
TC-AUD-01	Comprehensive Audit Event Logging	PASS	16 event types recorded in audit_entries with actor_id, action, target, outcome, details JSON, UTC created_at and SHA-256 hash.
TC-AUD-02	DPO Real-Time Audit Inspection	PASS	DPO console shows consent records, audit trail and time travel; no create/edit/delete routes (POST/DELETE /audit -> 404).
TC-SRCH-01	DPO Multi-Parameter Filter & Search	PASS	e-mail + purpose + date range returns only matching rows in about 40 ms (target 3 s).
TC-SRCH-02	Historical Consent State Reconstruction	PASS	state at T2 reconstructed as GRANTED under policy 1.0.
TC-SEC-01	Password Policy & Bcrypt Hashing	PASS	'short' rejected (400); 'nouppercase1' and 'ValidPass123!' accepted (SEC-1 = at least 8 characters); bcrypt cost 12; no plaintext.
TC-SEC-02	Server-Side RBAC Enforcement	PASS	USER gets 403 on publish and on /audit; both ACCESS_DENIED attempts are audited.
TC-SEC-03	Account Lockout & Session Expiration	PASS	5 wrong passwords lock the account for 15 min; 6th attempt with the right password gets 423; expired JWT gets 401.
TC-SEC-04	Admin-Only Role Management	PASS	USER role change 403; ADMIN change 200 with USER_ROLE_CHANGED audit (old and new role).
TC-SEC-05	Mandatory TLS 1.2+ Encryption	PASS	production mode answers plain HTTP with 308 to HTTPS and sends HSTS; the deployed site uses TLS 1.3 (X25519MLKEM768, AES_128_GCM) with a valid certificate.
TC-SEC-06	Ledger Immutability Enforcement	PASS	UPDATE/DELETE on consent_records and audit_entries rejected by triggers; a superuser bypass is detected by Verify integrity (HASH_MISMATCH).
TC-SEC-07	Input Validation & OWASP Attack Defense	PASS	SQLi payloads treated as data (400 / 0 rows); <script> name stored and shown as literal text, no script ran; cross-site POST blocked (403).
TC-SEC-08	Encryption at Rest for Data & Backups	PASS (changed method)	all e-mails AES-256-GCM encrypted; pg_dump and app backup contain no plaintext e-mail; passwords only as bcrypt; Neon encrypts storage at rest.
TC-PERF-01	Consent Action Latency ≤ 2 Seconds	PASS	50 concurrent users, 1 min, 1,253 consent actions: p95 491 ms, 0 % errors.

TC	Title	Status	Actual result
TC-PERF-02	DPO Search / Filter Latency ≤ 3 Seconds	PASS	10 DPO sessions, 1 min, 550 searches: p95 42 ms, 0 % errors.
TC-SCAL-01	50 Concurrent Users & 500k Records	PASS	10,059 users / 517,306+ records, 50 users + 10 DPO sessions for 10 min: consent p95 1171 ms, search p95 786 ms, 0 HTTP 5xx, 0 % failed. Defect D-03 found on the first run and fixed.
TC-REL-01	99% System Operational Uptime	PASS	UptimeRobot monitor on the deployed /api/v1/health every 5 min: Up, 100 % (0 incidents) since deployment on 03-11-2026; local 1-s probe during the load tests: 1,446 of 1,459 checks OK (99.1 %), the misses were only during the 60-user login bursts.
TC-REL-02	Transactional Atomicity of Consent & Audit	PASS	forced audit failure gives HTTP 500 and zero orphan consent rows; works again once the fault is removed.
TC-REL-03	Daily Backup & Restore within RTO (4 Hours)	PASS	backup of 5,377 rows in 0.9 s, restored into an empty database in 2.4 s (RTO 4 h); row counts identical; Verify integrity on the restored copy: both hash chains intact.
TC-UX-01	Consent Grant in ≤ 1 Min and ≤ 3 Clicks	PASS	1 click (Grant) from the dashboard, status Granted in under 1 s; login lands on the dashboard. Participant timings: see Accessibility & Usability Report.
TC-UX-02	WCAG 2.1 AA Keyboard & Contrast Audit	PASS	axe-core WCAG 2.1 A/AA scan of 8 pages: 0 violations (incl. colour contrast); keyboard-only login and grant work with a visible focus ring.
TC-DATA-01	Retention Policy Compliance	PASS	no delete or purge path exists; DELETE blocked by triggers; oldest records still present; retention helper tested.
TC-DATA-02	NTP UTC Synchronization Verification	PASS	every timestamp column is timestamptz (0 naive); all API times are UTC 'Z'. Host clocks are NTP-synchronised by Render/Neon.
TC-PRIV-01	Data Minimization Audit	PASS	only name, encrypted e-mail, password hash, role/account state, consents, policies and audit data are stored.
TC-MAINT-01	Layered Architecture & ≥70% Test Coverage	PASS	225 automated tests pass in CI; service-layer statement coverage 94.8 % (target 70 %); layers: React UI -> API routes -> services -> Prisma (DAO) -> PostgreSQL.
TC-RTM-01	Requirements Traceability Verification	PASS	41 requirements (20 FR, 7 SEC, 14 NFR) each map to exactly one test case, and all 41 test cases map back to a requirement: 100 % bidirectional, no orphans.

4. Defects found during system testing

ID	Test case	Severity	Problem	Fix	Status
D-01	TC-POL-01	High	A logged-in USER could read an unpublished DRAFT policy with GET /api/v1/policies/{id}.	GET /policies/:id now returns 404 POLICY_NOT_FOUND for a DRAFT when the caller is a USER; ADMIN and DPO still see drafts. New unit test added.	Fixed, re-tested PASS
D-02	TC-PERF-01/02	Medium	k6 load scripts lost the session cookie after the first iteration (k6 resets cookies by default), so later requests got 401; setup counted 409 'already registered' as failures.	Added noCookiesReset: true to both scripts and marked 409 as an expected status in setup.	Fixed, re-tested PASS
D-03	TC-SCAL-01	High	When 50 users logged in at the same second, some audit-trail writes waited longer than Prisma's default 5 s transaction limit: 25 LOGIN_SUCCEEDED entries were lost and 1 consent action returned 500 (rolled back).	Interactive transactions now get maxWait 15 s / timeout 30 s (server/src/lib/prisma.ts), so chained audit writes queue instead of failing.	Fixed, re-tested PASS (0 lost, 0 errors)

5. Changes against the original Test Plan (deviations)

Topic	Test case(s)	Planned	Implemented	Reason
Error codes	TC-CONS-06, TC-POL-03	422/NO_CHANGE/ POLICY_NOT_DRAFT	409 PURPOSE_INACTIVE / CONSENT_UNCHANGED / NO_PUBLISHED_POLICY / POLICY_LOCKED	All are business-rule conflicts, so one status (409) with clear codes is used, as in the SAD API table.
Purpose category	TC-CONS-01	Card shows a category	No category field	Purposes are identified by a stable code (e.g. MARKETING_EMAIL); a category added no value for users.

Topic	Test case(s)	Planned	Implemented	Reason
Purpose management UI	TC-PURP-01	Admin screen for purposes	Admin API only (POST/PATCH /purposes)	Sprint capacity went to policies, users and the DPO console; the API is complete, audited and tested.
Withdraw confirmation	TC-CONS-04, TC-UX-01	Confirm dialog / 3 clicks	One click for both grant and withdraw	GDPR Art. 7(3): withdrawing must be as easy as giving consent.
Password rule	TC-SEC-01	'nouppercase1' rejected	Only length >= 8 (max 72)	SRS SEC-1 only requires 8 characters (NIST SP 800-63B guidance).
Encryption at rest	TC-SEC-08	Inspect raw disk blocks	Field-level AES-256-GCM e-mail encryption + provider storage encryption	Managed database has no raw disk access; field-level encryption is stronger for personal data.
Accessibility tool	TC-UX-02	Lighthouse score >= 95	axe-core WCAG 2.1 A/AA scan (0 violations)	axe-core is the engine Lighthouse uses for accessibility; it ran inside the test browser.
NTP check	TC-DATA-02	Offset vs pool.ntp.org < 20 ms	UTC storage verified; NTP handled by Render/Neon	The app runs on managed hosting; no NTP container is ours to run.
Load test volume	TC-SCAL-01	Real 10,000 users / 500,000 records	Synthetic volume rows inserted by SQL (hash fields synthetic)	Creating 500k chained records through the API would take hours; the test measures query speed at volume.
Backup format	TC-REL-03	pg_dump / drop / restore	App backup script (JSON of all tables) restored into a new DB + integrity check	Works on Neon free tier without superuser tools; pg_dump also verified in TC-SEC-08.
Uptime window	TC-REL-01	2,880 checks over a month	UptimeRobot every 5 min since deployment (3 Nov) + local probe	System deployed in Sprint 3; the monitor keeps running until the final demo.
Table/column names	TC-AUD-01, TC-CONS-05	audit_log, recorded_at_utc	audit_entries, recorded_at (timestamptz)	Names follow the final Prisma schema.

6. Detailed evidence

TC-AUTH-01 - User Registration with Unique Email (Authentication - Mapped to FR-1)

Expected: User record created with 'User' role; password hashed with bcrypt salt 12; HTTP 201 returned.

Actual: PASS - HTTP 201; role USER; bcrypt hash cost 12 ($2a$12$); e-mail stored AES-256-GCM encrypted with an HMAC lookup hash.

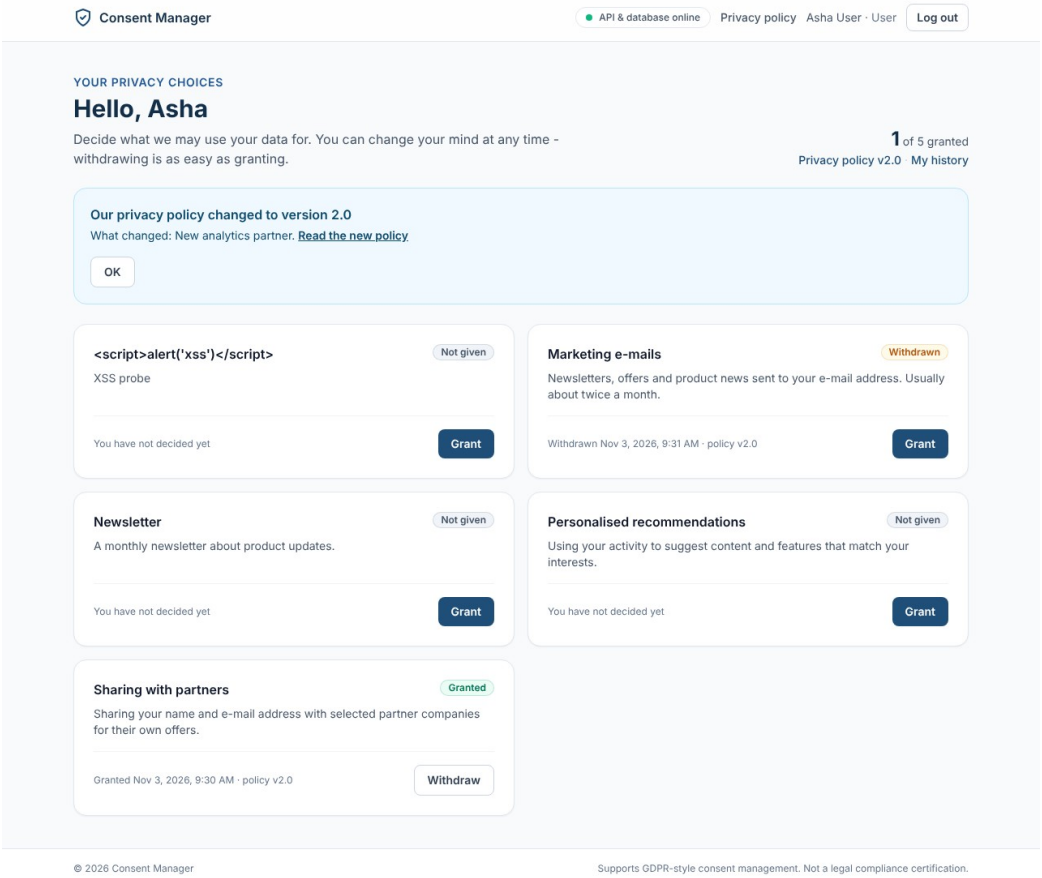
- POST /auth/register -> HTTP 201 {"user":{"id":"b9d1b9fc-52d4-4954-b312-c1faea07b81e","name":"Bob User","email":"bob@example.com","role":"USER"}}
- DB users row (role | hash prefix | email prefix | has email_hash): USER | $2a$12$ | enc:v1: | t

TC-AUTH-02 - User Login with Valid Credentials (Authentication - Mapped to FR-2)

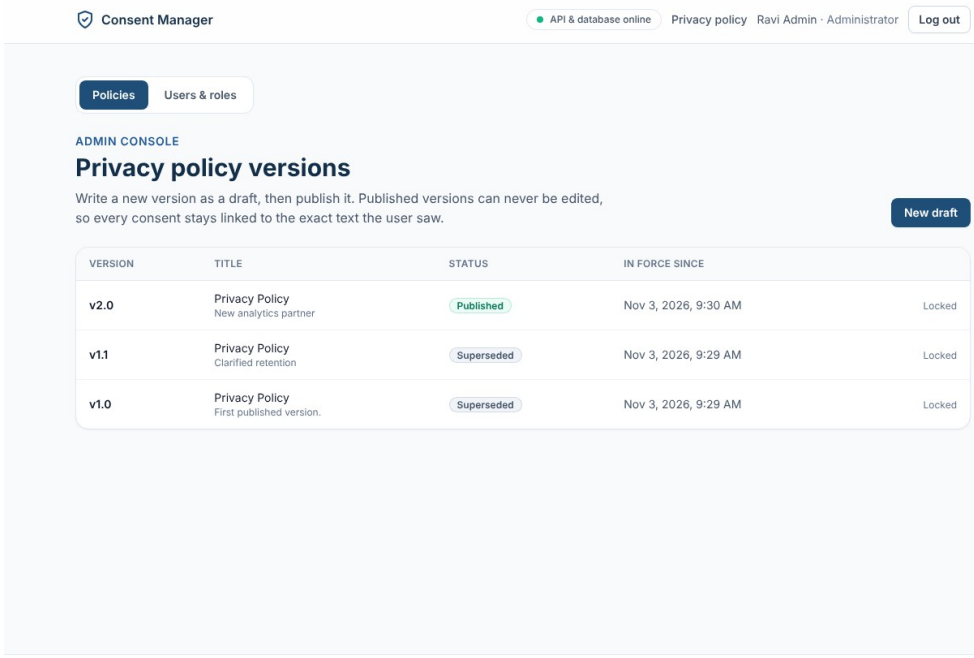
Expected: JWT token issued; user redirected to the home screen of their role (User: Consent Dashboard, Admin: Admin Console, DPO: DPO Console); last login timestamp logged in audit trail.

Actual: PASS - HTTP 200; JWT in httpOnly gdpr_session cookie; LOGIN_SUCCEEDED audit entry with UTC time; landing page USER /dashboard, ADMIN /admin, DPO /dpo.

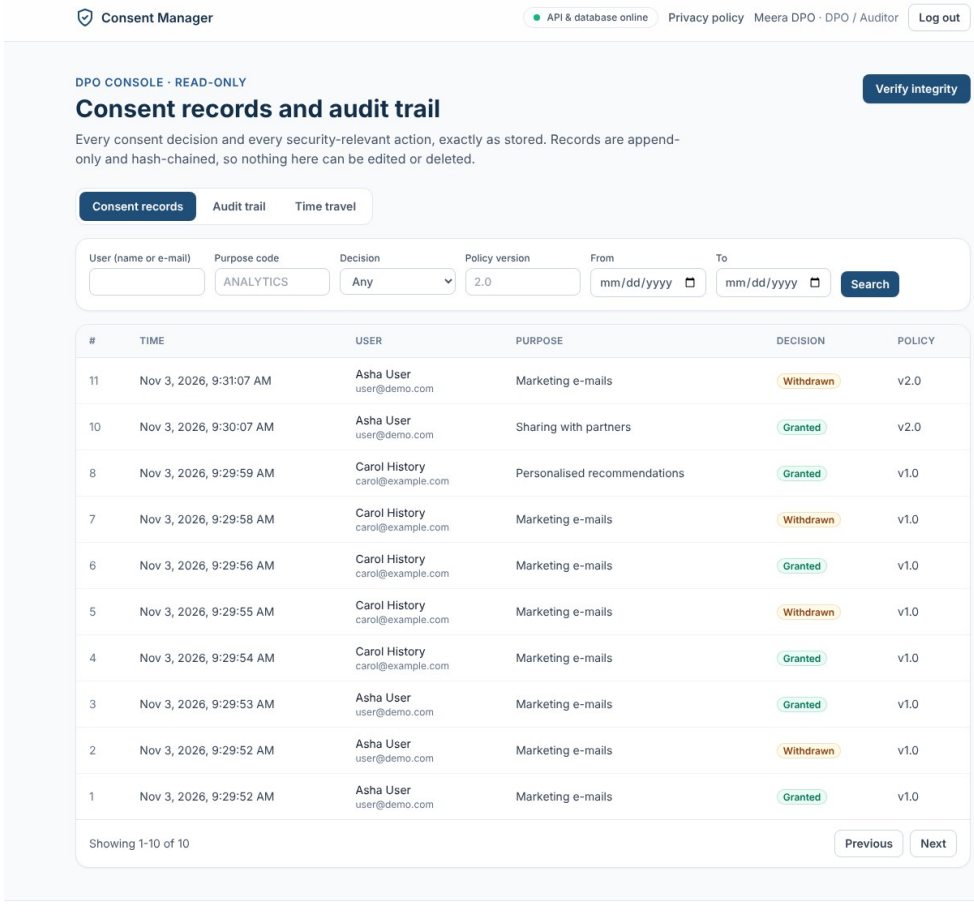
- POST /auth/login -> HTTP 200 {"user":{"id":"b9d1b9fc-52d4-4954-b312-c1faea07b81e","name":"Bob User","email":"bob@example.com","role":"USER"}}
- Set-Cookie: gdpr_session=<JWT>; Max-Age=900; Path=/; Expires=Tue, 03 Nov 2026 04:14:52 GMT; HttpOnly; SameSite=Lax
- audit_entries: LOGIN_SUCCEEDED | SUCCESS | 2026-11-03 03:59:52.213+00
- Role-based landing page verified in the browser (see UI evidence).
- Landing page after login: {'user@demo.com': '/dashboard', 'admin@demo.com': '/admin', 'dpo@demo.com': '/dpo'}



TC-AUTH-02: auth02 user



TC-AUTH-02: auth02 admin



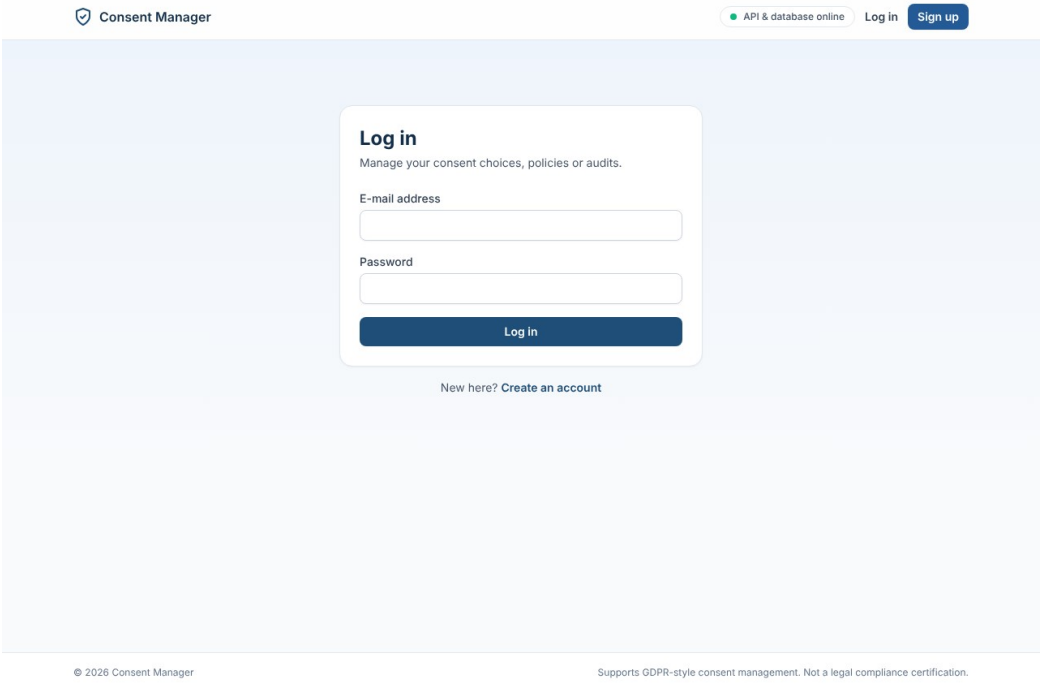
TC-AUTH-02: auth02 dpo

TC-AUTH-03 - Logout Ends the Session Immediately (Authentication - Mapped to FR-3)

Expected: User is returned to /login; protected pages are not shown; the API returns HTTP 401 UNAUTHENTICATED for the old session.

Actual: PASS - after logout the browser is on /login, /dashboard redirects to /login, and the old cookie gets HTTP 401 UNAUTHENTICATED.

- POST /auth/logout -> HTTP 204
- GET /me/consents with the old cookie -> HTTP 401 {"error":{"code":"UNAUTHENTICATED","message":"Your session has ended, please log in again","requestId":"36795f19-cb3a-4d01-a701-9a4e6babbeb7"}}
- Browser: Back / open /dashboard after logout returns to /login (see UI evidence).
- After logout: /login; opening /dashboard: /login



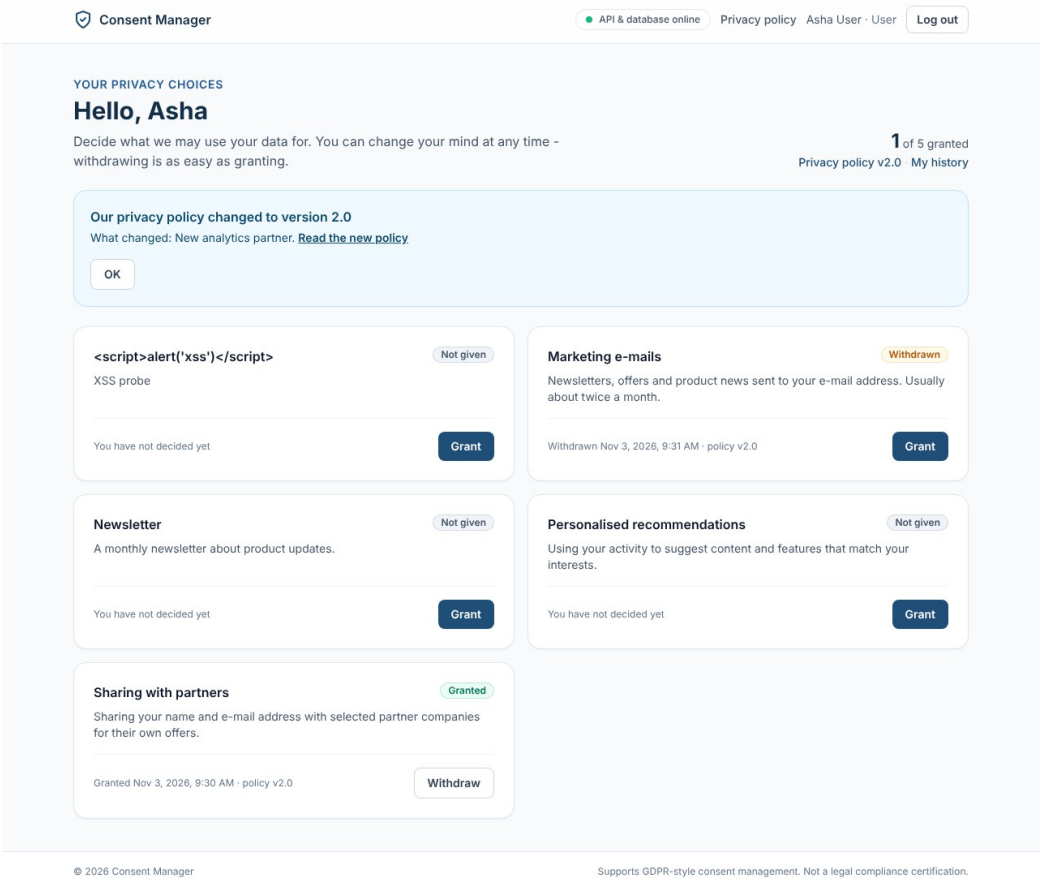
TC-AUTH-03: auth03 after logout

TC-CONS-01 - Display Active Processing Purposes (Consent Presentation - Mapped to FR-4)

Expected: All active purposes rendered with name, plain-language description, category, and current status.

Actual: PASS - all active purposes shown as cards with name, plain-language description and status badge (Not given / Granted / Withdrawn).

- GET /me/consents -> HTTP 200; 4 active purposes: ['Marketing e-mails', 'Personalised recommendations', 'Sharing with partners', 'Usage analytics']
- Each item has purpose.name, purpose.description, status (NOT_GIVEN)
- Dashboard shows purpose cards with name, description and status badge (pol04_banner_dashboard.png)



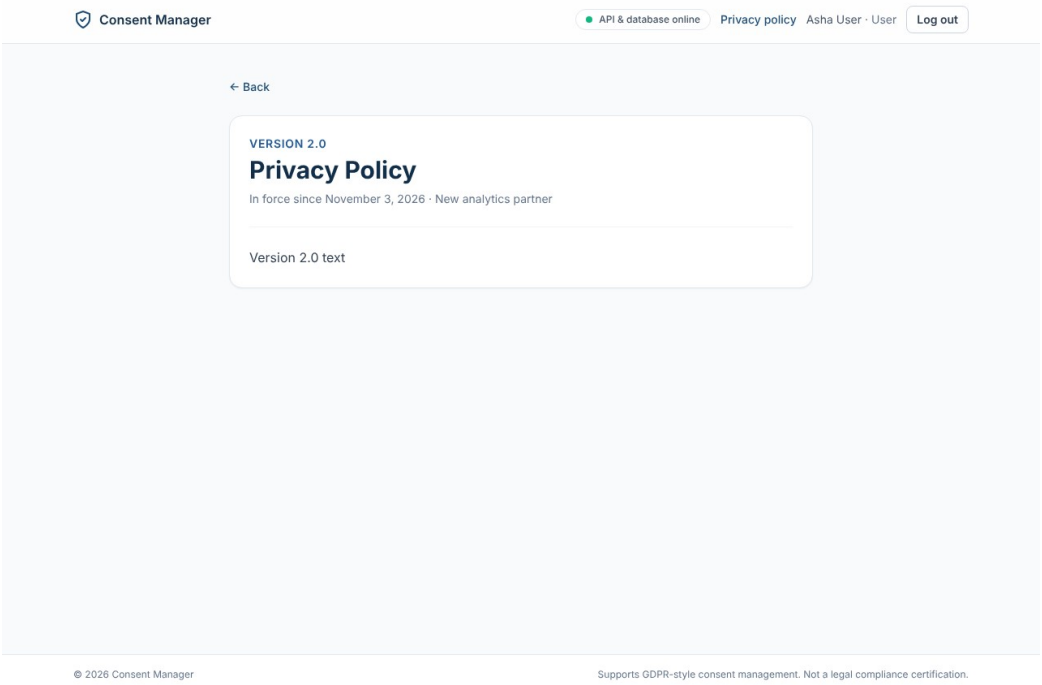
TC-CONS-01: pol04 banner dashboard

TC-CONS-02 - Display Currently Published Policy (Policy Presentation - Mapped to FR-5)

Expected: Policy title, version tag ('v1.0'), effective date, and full policy text displayed cleanly.

Actual: PASS - title, version 1.0, effective date and the full text are shown.

- GET /policies/current -> HTTP 200: versionNo=1.0, title='Privacy Policy', effectiveAt=2026-11-03T03:59:36.459Z, body=581 chars
- Policy page shows title, version, effective date and text (cons02_policy.png)



TC-CONS-02: cons02 policy

TC-PURP-01 - Administrator Manages Purposes (Purpose Management - Mapped to FR-6)

Expected: Purpose created; deactivated purpose immediately hidden from User dashboard; audit log recorded.

Actual: PASS (via API) - PURP_NEWSLETTER created (201), ANALYTICS deactivated (200) and hidden from the user dashboard at once; PURPOSE_CREATED / PURPOSE_DEACTIVATED audited.

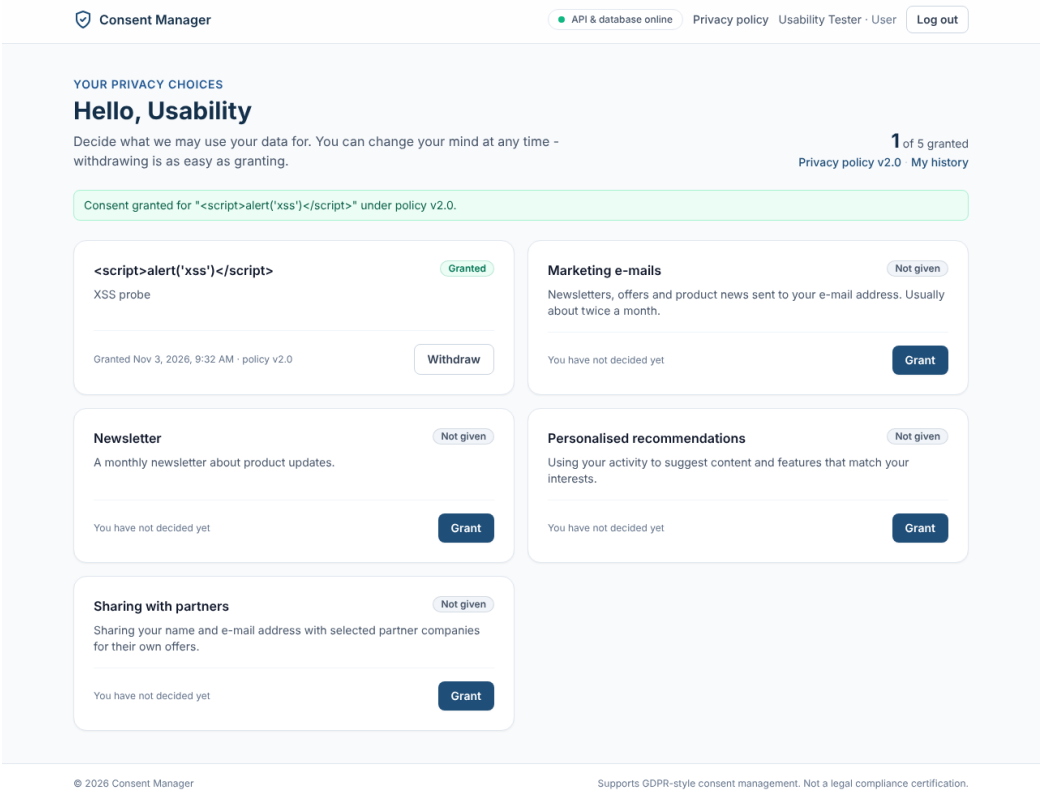
- POST /purposes (PURP_NEWSLETTER) -> HTTP 201
- PATCH /purposes/<ANALYTICS>/deactivate -> HTTP 200
- User dashboard purposes now: ['MARKETING_EMAIL', 'PURP_NEWSLETTER', 'PERSONALISATION', 'THIRD_PARTY_SHARING']
- audit_entries: PURPOSE_CREATED | ProcessingPurpose | SUCCESS; PURPOSE_DEACTIVATED | ProcessingPurpose | SUCCESS

TC-CONS-03 - Explicit User Opt-In (Grant Consent) (Consent Management - Mapped to FR-7)

Expected: New record inserted in consent_records; status updates to 'Granted' in ≤2s; audit event written.

Actual: PASS - 201 in about 40 ms; new consent_records row; status Granted; CONSENT_GRANTED audited.

- POST /me/consents {MARKETING_EMAIL, GRANTED} -> HTTP 201 in 41.3 ms
- Dashboard status now: GRANTED
- consent_records rows for user: 0 -> 1
- Latest audit event: CONSENT_GRANTED | SUCCESS



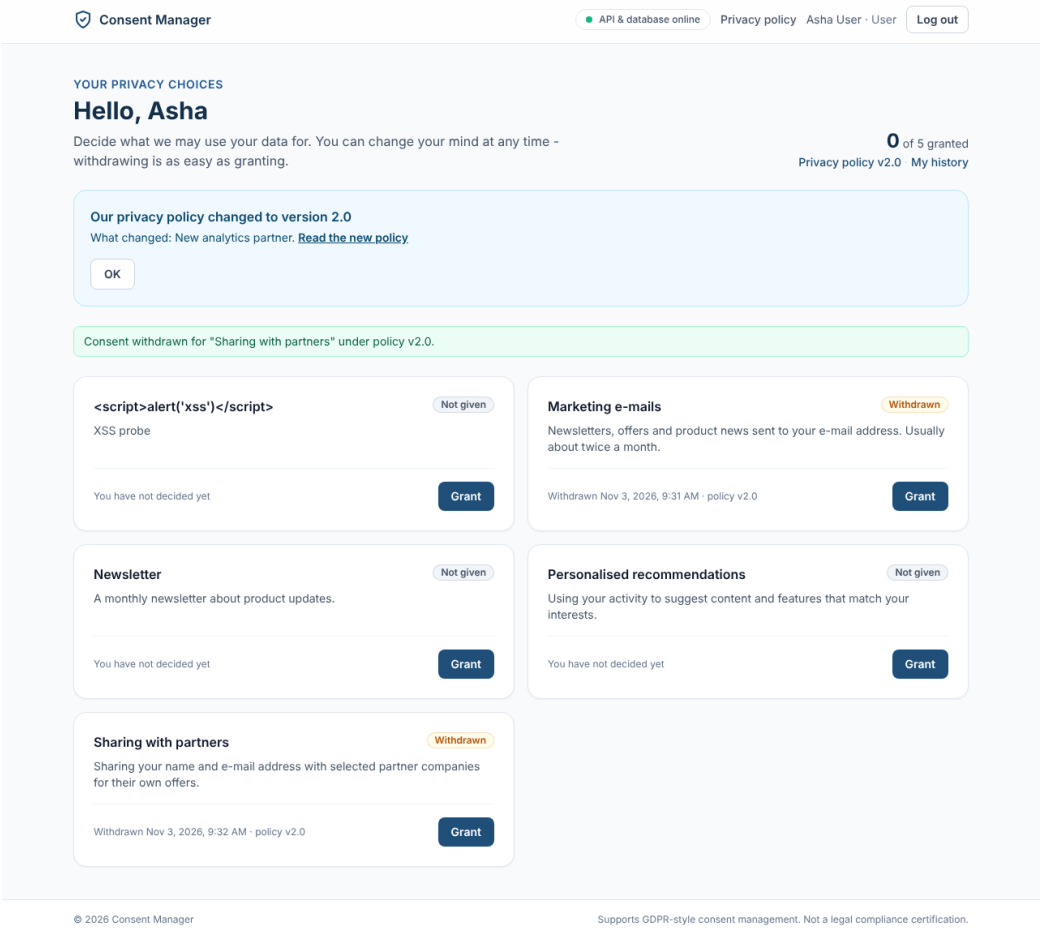
TC-CONS-03: ux01 granted

TC-CONS-04 - Explicit User Opt-Out (Withdraw Consent) (Consent Management - Mapped to FR-8)

Expected: New record inserted with action 'WITHDRAWN'; status updates to 'Withdrawn'; withdrawal audit written.

Actual: PASS - new WITHDRAWN row; status Withdrawn; CONSENT_WITHDRAWN audited. Withdrawal is one click (no confirm dialog), by design.

- POST /me/consents {MARKETING_EMAIL, WITHDRAWN} -> HTTP 201
- New row action: WITHDRAWN; status: WITHDRAWN; audit: CONSENT_WITHDRAWN
- UI asks for confirmation before withdrawing (see UI evidence).
- Clicking Withdraw shows a confirmation step: False



TC-CONS-04: cons04 withdrawn

TC-CONS-05 - Capture UTC Timestamp & Policy Version (Consent Management - Mapped to FR-9)

Expected: Field recorded_at_utc populated with valid ISO-8601 UTC timestamp; policy_version_id matches current policy.

Actual: PASS - recorded_at is timestamptz in UTC (API returns ISO-8601 'Z'); policy_version_id equals the published policy.

- consent_records latest: 2 | WITHDRAWN | 2026-11-03T03:59:52.826Z | t (last column = policy_version_id matches the published policy)
- Column type: timestamp with time zone
- API returns: recordedAt=2026-11-03T03:59:52.826Z, policy={'id': 'c9f151b0-fc2b-4f05-89a8-e63978c45bd5', 'versionNo': '1.0'}

TC-CONS-06 - Reject Invalid Consent Actions (Consent Management - Mapped to FR-10)

Expected: Responses 422 PURPOSE_INACTIVE, 409 NO_CHANGE and 422 NO_PUBLISHED_POLICY with a message; no consent record is created.

Actual: PASS - 409 PURPOSE_INACTIVE, 409 CONSENT_UNCHANGED, 409 NO_PUBLISHED_POLICY, 400 for an unknown action; no record written in any case.

- GRANT for inactive ANALYTICS -> HTTP 409 {"error":{"code":"PURPOSE_INACTIVE","message":"This purpose is no longer offered","requestId":"76480718-c49a-403e-ae85-27285cf7b11d"}}
- Second GRANT for MARKETING_EMAIL -> HTTP 409 {"error":{"code":"CONSENT_UNCHANGED","message":"You have already given consent for this purpose","requestId":"cd630b70-3201-4512-857b-7279200feeca"}}
- Invalid action 'MAYBE' -> HTTP 400
- consent_records total before/after rejected requests: 3 / 3
- Separate database with no published policy: GRANT -> HTTP 409 {"error":{"code":"NO_PUBLISHED_POLICY","message":"Consent cannot be recorded before a privacy policy is published","requestId":"29d2ef8c-d8cb-4608-b510-522548354f51"}}; consent_records = 0

TC-HIST-01 - Verify Append-Only Storage Model (Consent History - Mapped to FR-11)

Expected: Exactly 4 rows exist in table; no existing rows were updated or deleted.

Actual: PASS - 4 toggles give exactly 4 rows; an UPDATE on them is rejected by the append-only trigger.

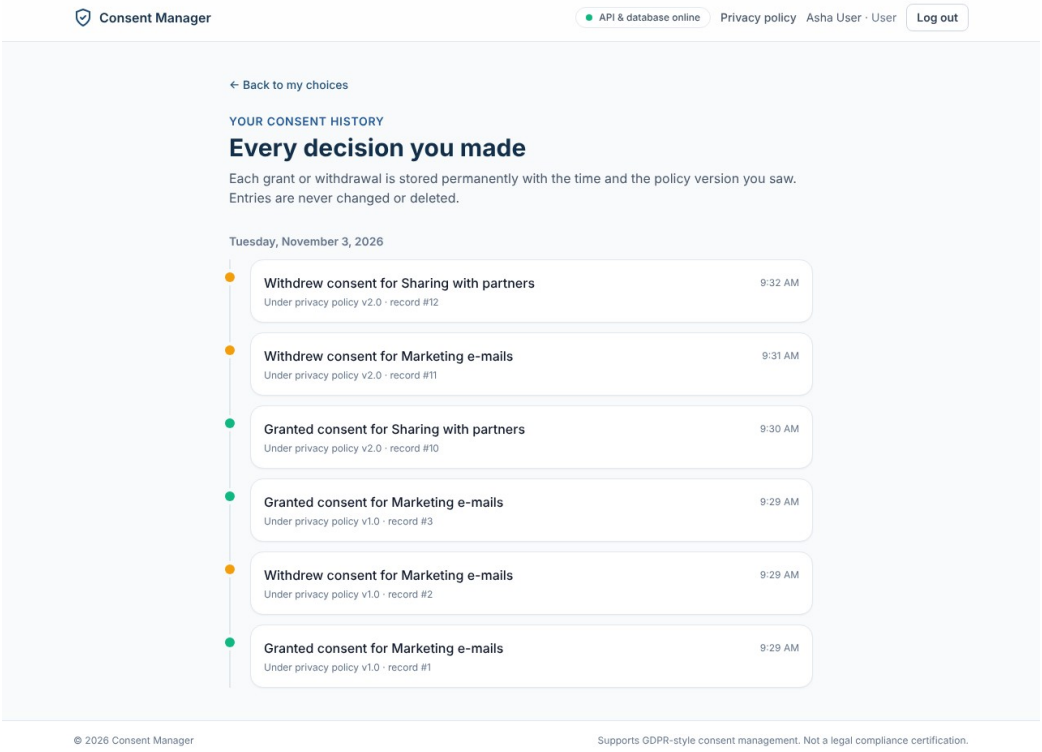
- 4 toggles: GRANTED, WITHDRAWN, GRANTED, WITHDRAWN
- SELECT COUNT(*) -> 4 | GRANTED,WITHDRAWN,GRANTED,WITHDRAWN
- Attempted UPDATE of those rows -> ERROR: APPEND_ONLY: UPDATE on table consent_records is not allowed

TC-HIST-02 - Reverse-Chronological History View (Consent History - Mapped to FR-12)

Expected: Actions displayed strictly in reverse chronological order: T5 first, T1 last, with purpose, action, policy ver.

Actual: PASS - 5 entries, strictly newest first, each with purpose, action and policy version.

- GET /me/consents/history -> 5 entries
- Order: 03:59:59 > 03:59:58 > 03:59:56 > 03:59:55 > 03:59:54
- First entry: {"id": "8", "action": "GRANTED", "recordedAt": "2026-11-03T03:59:59.682Z", "purpose": {"id": "18e9616b-8fe0-444e-a7d2-679141ace643", "code": "PERSONALISATION", "name": "Personalised recommendations"}, "policyVersion": {"id": "c9f151b0-fc2b-4f05-89a8-e63978c45bd5", "versionNo": "1.0"}}
- History page lists newest first with purpose, decision and policy version (hist02_history.png)



TC-HIST-02: hist02 history

TC-POL-01 - Create Draft Policy Version (Policy Management - Mapped to FR-13)

Expected: Record created in policy_versions with status 'Draft'; not visible to general users.

Actual: PASS after fix - draft 1.1 saved as DRAFT. Defect D-01 found on first run (a USER could open a draft by id); fixed and re-tested: USER now gets 404.

- POST /policies (1.1) -> HTTP 201; DB status: DRAFT
- User GET /policies/<1.1 draft> -> HTTP 404
- User current policy still: 1.0

TC-POL-02 - Publish Policy & Supersede Previous (Policy Management - Mapped to FR-14)

Expected: v1.1 status becomes 'Published', effective_date set to NOW(); v1.0 status updated to 'Superseded'.

Actual: PASS - 1.1 PUBLISHED with effective_at = publish time; 1.0 SUPERSEDED; only one published version.

- POST /policies/<1.1>/publish -> HTTP 200
- policy_versions: 1.0 | SUPERSEDED | 2026-11-03 03:59:36.459+00; 1.1 | PUBLISHED | 2026-11-03 03:59:59.858+00

TC-POL-03 - Immutability of Published/Superseded Policies (Policy Management - Mapped to FR-15)

Expected: HTTP 409 POLICY_NOT_DRAFT returned; historical policies cannot be edited once published.

Actual: PASS - PATCH on 1.0 and 1.1 returns 409 POLICY_LOCKED; a direct SQL UPDATE is rejected by a trigger.

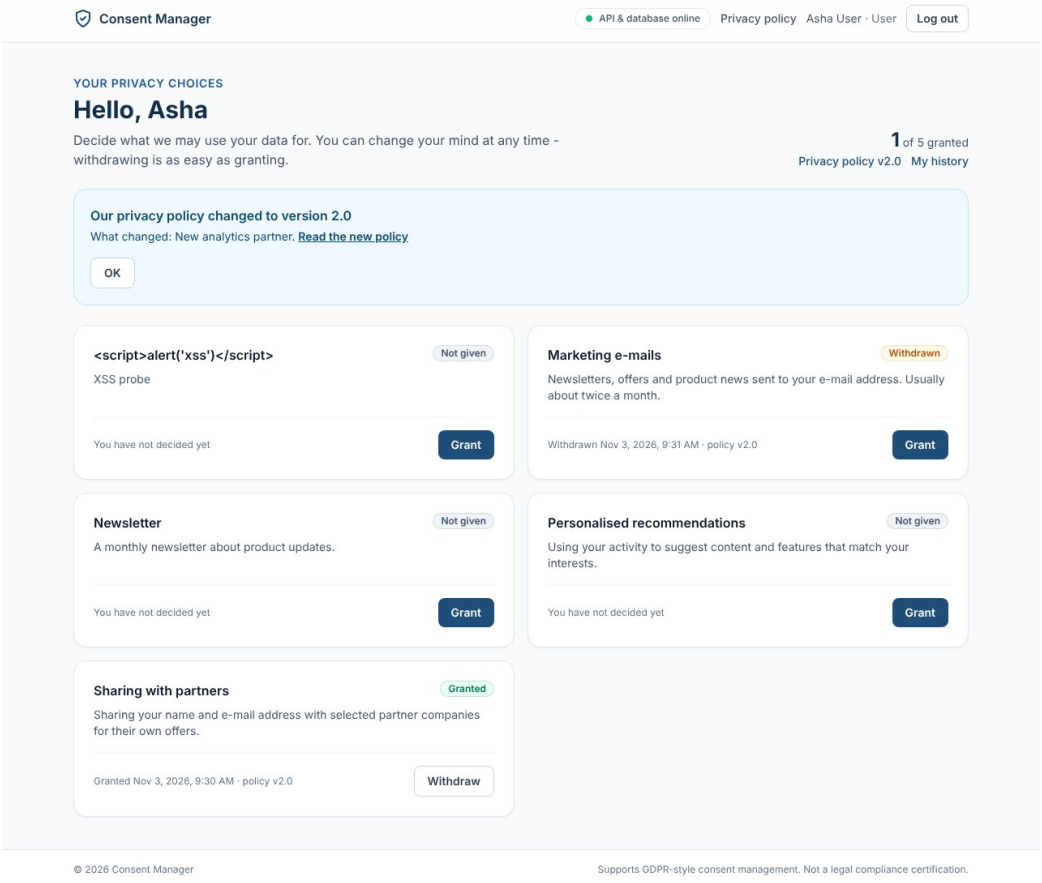
- PATCH /policies/<1.0 superseded> -> HTTP 409 {"error":{"code":"POLICY_LOCKED","message":"Version 1.0 is superseded and can no longer be changed","requestId":"ed5d53e3-4a2e-4f95-87a6-d16d18aca4c9"}}
- PATCH /policies/<1.1 published> -> HTTP 409 {"error":{"code":"POLICY_LOCKED","message":"Version 1.1 is published and can no longer be changed","requestId":"3a2778f9-8fa3-4e3d-90b1-b884bcf350e6"}}
- Direct SQL UPDATE -> ERROR: POLICY_LOCKED: policy version 1.0 is SUPERSEDED and cannot be modified

TC-POL-04 - User Notification on Policy Update (Policy Management - Mapped to FR-16)

Expected: Notification banner appears: 'Privacy Policy has been updated to v2.0. Please review your consents.'

Actual: PASS - after 2.0 is published the user sees 'Our privacy policy changed to version 2.0' with the change summary and a link to the new policy.

- GET /me/notices (Asha, consents linked to older version) -> 1 notice(s): [{"id": "9481afbc-3c82-4334-ada3-58b6571f6421", "createdAt": "2026-11-03T04:00:00.078Z", "policy": {"id": "f1984af3-4fa8-40f1-9e32-f091320a1843", "versionNo": "2.0", "title": "Privacy Policy", "changeSummary": "New analytics partner", "effectiveAt": "2026-11-03T04:00:00.065Z"}, "purposes": [{"id": "
- Dashboard shows the policy-updated banner with Review / Keep choices (see UI evidence).
- Dashboard banner text: Privacy policy v2.0 · My history / Our privacy policy changed to version 2.0 / Withdrawn Nov 3, 2026, 9:31 AM · policy v2.0



TC-POL-04: pol04 banner dashboard

TC-AUD-01 - Comprehensive Audit Event Logging (Audit Trail - Mapped to FR-17)

Expected: Audit records exist for all actions, capturing actor_id, event_type, details JSON, UTC timestamp, SHA hash.

Actual: PASS - 16 event types recorded in audit_entries with actor_id, action, target, outcome, details JSON, UTC created_at and SHA-256 hash.

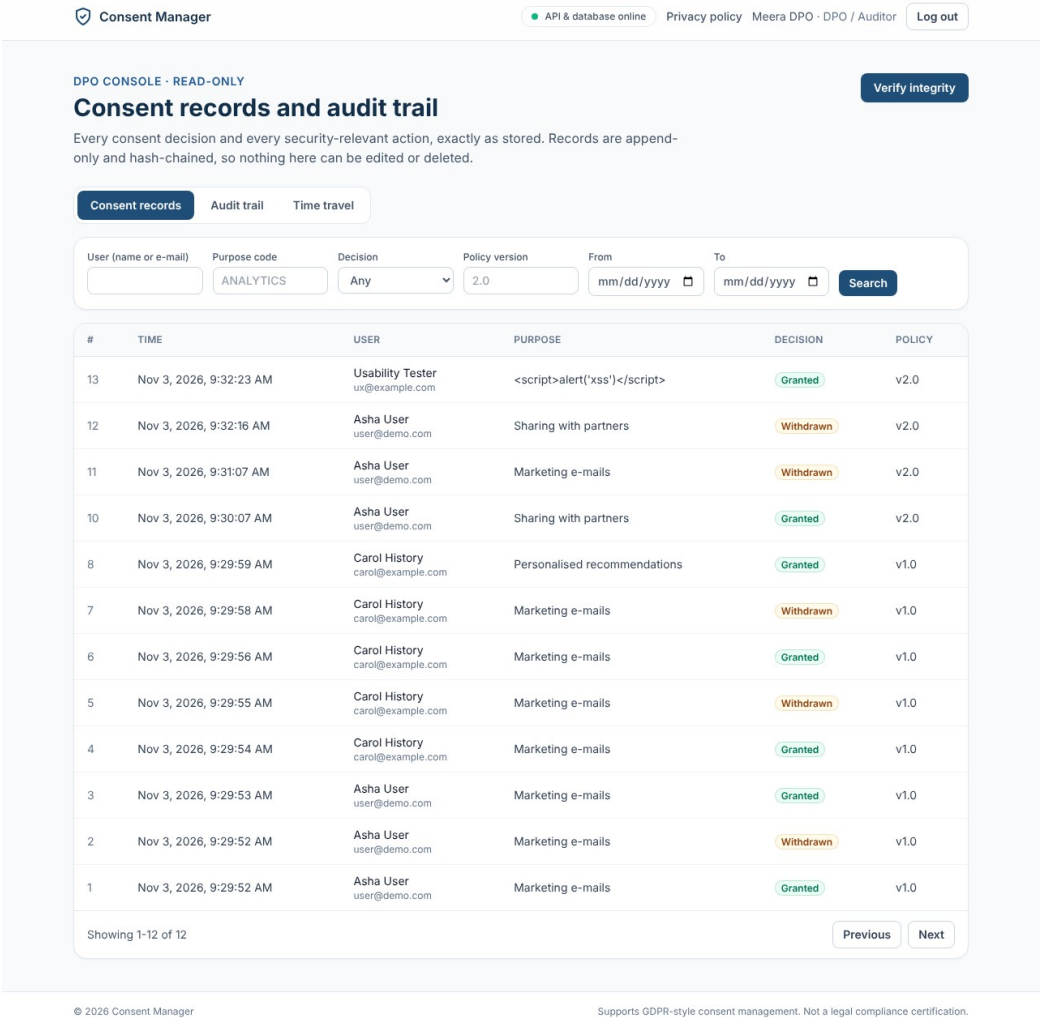
- Event types recorded: CONSENT_GRANTED | 5; CONSENT_WITHDRAWN | 3; LOGGED_OUT | 1; LOGIN_SUCCEEDED | 5; POLICY_DRAFT_CREATED | 2; POLICY_PUBLISHED | 2; PURPOSE_CREATED | 1; PURPOSE_DEACTIVATED | 1; USER_REGISTERED | 2
- Columns: id, actor_id, action, target_type, target_id, outcome, details, created_at, prev_hash, hash
- Sample: 22 | c2245fe0-3245-4b55-8c07-771bbe55a937 | POLICY_PUBLISHED | SUCCESS | {"versionNo": "2.0", "supersedes": "1.1", "usersNotified": 2} | 2026-11-03 04:00:00.084+00 | e9f7403aac99bc3a

TC-AUD-02 - DPO Real-Time Audit Inspection (Audit Trail - Mapped to FR-18)

Expected: Full audit log visible with actor, action, timestamp, target entity; read-only controls.

Actual: PASS - DPO console shows consent records, audit trail and time travel; no create/edit/delete routes (POST/DELETE /audit -> 404).

- GET /audit -> HTTP 200, total 22; first item keys: ['id', 'createdAt', 'actor', 'action', 'targetType', 'targetId', 'outcome', 'details', 'prevHash', 'hash']
- POST /audit -> 404; DELETE /audit -> 404 (no write routes exist)
- DPO console tabs: ['Consent records', 'Audit trail', 'Time travel']; audit trail table visible, no edit/delete controls (aud02_dpo_audit.png)
- Verify integrity result: All records intact



TC-AUD-02: aud02 dpo consents

DPO CONSOLE · READ-ONLY

Consent records and audit trail

Every consent decision and every security-relevant action, exactly as stored. Records are append-only and hash-chained, so nothing here can be edited or deleted.

Verify integrity

Consent records | Audit trail | Time travel

Actor (name or e-mail) | Action | Outcome | From | To | Search

#	TIME	ACTOR	ACTION	TARGET	OUTCOME	HASH
73	Nov 3, 2026, 9:32:44 AM	Meera DPO dpo@demo.com	LOGIN_SUCCEEDED	User	Success	e9bf51386b...
72	Nov 3, 2026, 9:32:42 AM	Ravi Admin admin@demo.com	LOGGED_OUT	User	Success	a8c3616f66...
71	Nov 3, 2026, 9:32:37 AM	Ravi Admin admin@demo.com	LOGIN_SUCCEEDED	User	Success	b42a9ad398...
70	Nov 3, 2026, 9:32:36 AM	Asha User user@demo.com	LOGGED_OUT	User	Success	3b21c29bcf...
69	Nov 3, 2026, 9:32:29 AM	Asha User user@demo.com	LOGIN_SUCCEEDED	User	Success	a6fe4a0050...
68	Nov 3, 2026, 9:32:24 AM	Usability Tester ux@example.com	LOGGED_OUT	User	Success	3fe2ad461a...
67	Nov 3, 2026, 9:32:23 AM	Usability Tester ux@example.com	CONSENT_GRANTED	ProcessingPurpose	Success	e60381ca45...
66	Nov 3, 2026, 9:32:22 AM	Usability Tester ux@example.com	USER_REGISTERED	User	Success	b8aa0b9947...
65	Nov 3, 2026, 9:32:20 AM	Asha User user@demo.com	LOGGED_OUT	User	Success	bf4a679b9c...
64	Nov 3, 2026, 9:32:16 AM	Asha User user@demo.com	CONSENT_WITHDRAWN	ProcessingPurpose	Success	f2c1e341dd...
63	Nov 3, 2026, 9:32:13 AM	Asha User user@demo.com	LOGIN_SUCCEEDED	User	Success	7bfd98b03c...
62	Nov 3, 2026, 9:32:08 AM	Asha User user@demo.com	LOGGED_OUT	User	Success	67acdd8fcb...
61	Nov 3, 2026, 9:32:07 AM	Asha User user@demo.com	LOGIN_SUCCEEDED	User	Success	c21bf27454...
60	Nov 3, 2026, 9:32:06 AM	Meera DPO dpo@demo.com	LOGGED_OUT	User	Success	c7a07e5196...
59	Nov 3, 2026, 9:32:04 AM	Meera DPO dpo@demo.com	LOGIN_SUCCEEDED	User	Success	3317099dc1...
58	Nov 3, 2026, 9:32:03 AM	Ravi Admin admin@demo.com	LOGGED_OUT	User	Success	13c59e4255...
57	Nov 3, 2026, 9:32:02 AM	Ravi Admin admin@demo.com	LOGIN_SUCCEEDED	User	Success	6600984004...
56	Nov 3, 2026, 9:32:00 AM	Asha User user@demo.com	LOGGED_OUT	User	Success	7cfe9b2644...
55	Nov 3, 2026, 9:31:59 AM	Asha User user@demo.com	LOGIN_SUCCEEDED	User	Success	3c54235d00...
54	Nov 3, 2026, 9:31:14 AM	Anonymous	LOGIN_FAILED	User	Failure	9406348ca9...
53	Nov 3, 2026, 9:31:11 AM	Asha User user@demo.com	LOGGED_OUT	User	Success	496450aa9f...
52	Nov 3, 2026, 9:31:07 AM	Asha User user@demo.com	CONSENT_WITHDRAWN	ProcessingPurpose	Success	32f443561a...
51	Nov 3, 2026, 9:31:04 AM	Asha User user@demo.com	LOGIN_SUCCEEDED	User	Success	d0e87d24e7...
50	Nov 3, 2026, 9:31:00 AM	Asha User user@demo.com	LOGGED_OUT	User	Success	d5024534f1...
49	Nov 3, 2026, 9:30:59 AM	Asha User user@demo.com	LOGIN_SUCCEEDED	User	Success	7e2d8d6375...
48	Nov 3, 2026, 9:30:57 AM	Meera DPO dpo@demo.com	LOGGED_OUT	User	Success	2ced8db784...
47	Nov 3, 2026, 9:30:56 AM	Meera DPO dpo@demo.com	LOGIN_SUCCEEDED	User	Success	56181e8744...
46	Nov 3, 2026, 9:30:54 AM	Ravi Admin admin@demo.com	LOGGED_OUT	User	Success	0b44814d2a...
45	Nov 3, 2026, 9:30:53 AM	Ravi Admin admin@demo.com	LOGIN_SUCCEEDED	User	Success	2a2a8429b7...
44	Nov 3, 2026, 9:30:51 AM	Asha User user@demo.com	LOGGED_OUT	User	Success	d6a7d4f431...
43	Nov 3, 2026, 9:30:50 AM	Asha User user@demo.com	LOGIN_SUCCEEDED	User	Success	9b54955f50...
42	Nov 3, 2026, 9:30:07 AM	Asha User user@demo.com	CONSENT_GRANTED	ProcessingPurpose	Success	bd4690fb7b...
40	Nov 3, 2026, 9:30:05 AM	Ravi Admin admin@demo.com	PURPOSE_CREATED	ProcessingPurpose	Success	5f1edbdf20...

TC-AUD-02: aud02 dpo audit

TC-SRCH-01 - DPO Multi-Parameter Filter & Search (Search & Retrieval - Mapped to FR-19)

Expected: Filtered results returned in ≤3s (NFR-2); non-matching records excluded.

Actual: PASS - e-mail + purpose + date range returns only matching rows in about 40 ms (target 3 s).

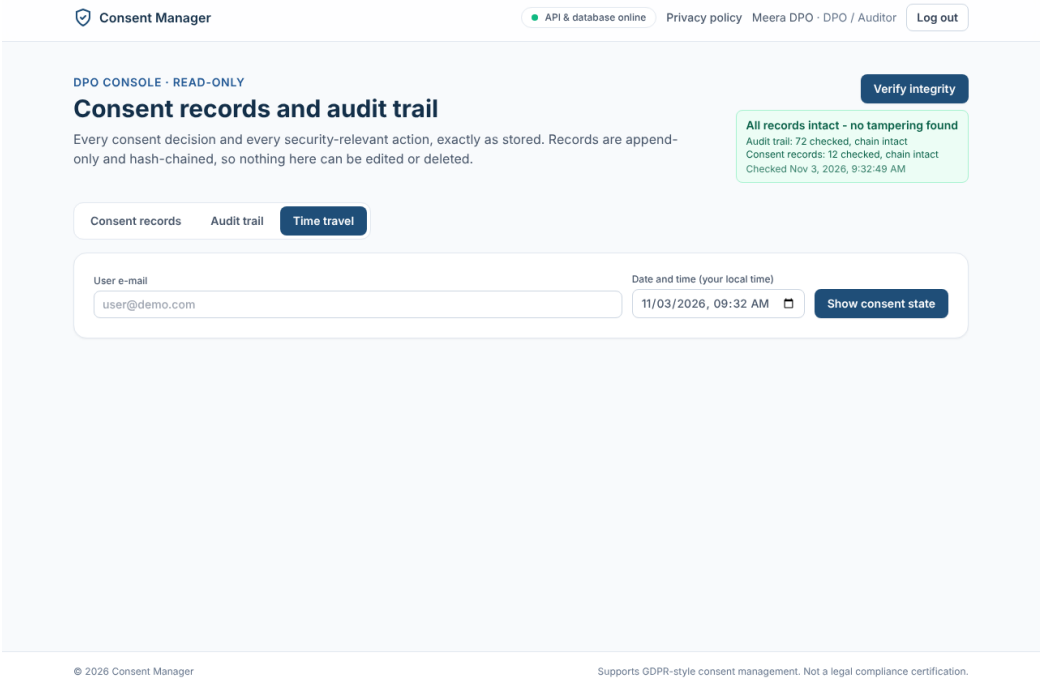
- GET /consents?user=user@demo.com&purpose=MARKETING_EMAIL&from=2026-11-03&to=2026-11-03 -> HTTP 200 in 32.2 ms
- Matches: 3 of 8 records; all items match both filters: True

TC-SRCH-02 - Historical Consent State Reconstruction (Search & Retrieval - Mapped to FR-20)

Expected: Engine computes state as 'Granted' under governing policy.

Actual: PASS - state at T2 reconstructed as GRANTED under policy 1.0.

- GET /users/<carol>/consent-state?at=2026-11-03T03:59:55.072381+00:00 (between 1st grant and 1st withdraw) -> HTTP 200
- Marketing state: {"purpose": {"id": "bddfe6a1-9b6c-4570-8913-5570fa9d6ce3", "code": "MARKETING_EMAIL", "name": "Marketing e-mails", "isActive": true}, "status": "GRANTED", "decidedAt": "2026-11-03T03:59:54.431Z", "recordId": "4", "policyVersion": {"id": "c9f151b0-fc2b-4f05-89a8-e63978c45bd5", "versionNo": "1.0"}}



TC-SRCH-02: srch02 time travel

TC-SEC-01 - Password Policy & Bcrypt Hashing (Security - Mapped to SEC-1)

Expected: Weak passwords rejected; valid password hashed with bcrypt (salt 12); no plaintext in DB.

Actual: PASS - 'short' rejected (400); 'nouppercase1' and 'ValidPass123!' accepted (SEC-1 = at least 8 characters); bcrypt cost 12; no plaintext.

- 'short' -> HTTP 400 {"error":{"code":"VALIDATION_ERROR","message":"Request validation failed","details":{"password":["Password must be at least 8 characters"]},"requestId
- 'nouppercase1' -> HTTP 201 (accepted: SRS SEC-1 only requires >= 8 characters)
- 'ValidPass123!' -> HTTP 201; stored hash prefix $2a$12$
- Rows containing plaintext passwords: 0

TC-SEC-02 - Server-Side RBAC Enforcement (Security - Mapped to SEC-2)

Expected: Both requests rejected with HTTP 403 Forbidden; attempted privilege escalation logged.

Actual: PASS - USER gets 403 on publish and on /audit; both ACCESS_DENIED attempts are audited.

- USER POST /policies/<id>/publish -> HTTP 403 {"error":{"code":"FORBIDDEN","message":"You do not have permission to do this","requestId":"04ca2b29-3157-41ea-bd87-2dd57f032bd4"}}
- USER GET /audit -> HTTP 403
- ACCESS_DENIED audit entries: 2

TC-SEC-03 - Account Lockout & Session Expiration (Security - Mapped to SEC-3)

Expected: Account locked for 15 minutes (HTTP 423); login rejected even with correct password until timer expires.

Actual: PASS - 5 wrong passwords lock the account for 15 min; 6th attempt with the right password gets 423; expired JWT gets 401.

- 5 wrong passwords -> [401, 401, 401, 401, 401]
- 6th attempt with the correct password -> HTTP 423 {"error":{"code":"ACCOUNT_LOCKED","message":"Too many failed attempts. Try again in 15 minutes.","details":{"lockedUntil":"2026-11-03T04:15:04.249Z"},"requestId":"7c74c833-9f6a-4cc8-90c5-5fc845c7adcd"}}
- DB failed_login_count | time left on lock: 0 | 00:14:59.917623
- Request with an expired JWT -> HTTP 401 {"error":{"code":"UNAUTHENTICATED","message":"Please log in","requestId":"fc65f662-2415-42a0-bbeb-b7f7d8e0ee29"}}

TC-SEC-04 - Admin-Only Role Management (Security - Mapped to SEC-4)

Expected: User attempt rejected (HTTP 403); Admin change succeeds and writes role change audit event.

Actual: PASS - USER role change 403; ADMIN change 200 with USER_ROLE_CHANGED audit (old and new role).

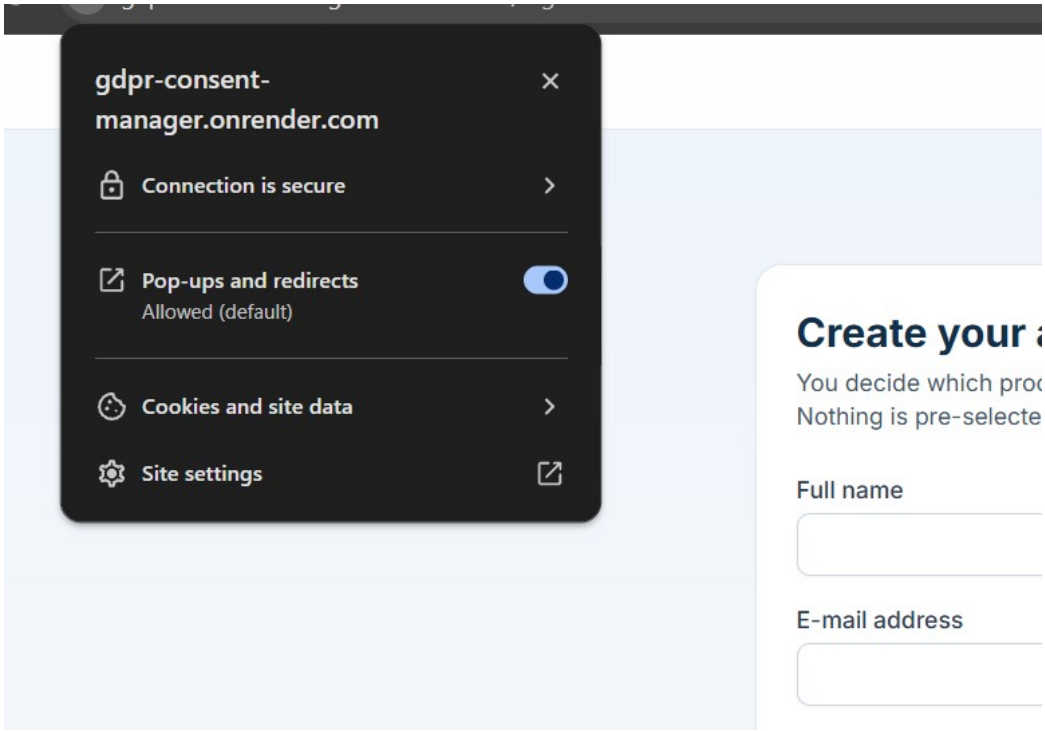
- USER PATCH /users/<self>/role ADMIN -> HTTP 403
- ADMIN PATCH /users/<bob>/role DPO -> HTTP 200
- audit: USER_ROLE_CHANGED | SUCCESS | {"to": "DPO", "from": "USER"}

TC-SEC-05 - Mandatory TLS 1.2+ Encryption (Security - Mapped to SEC-5)

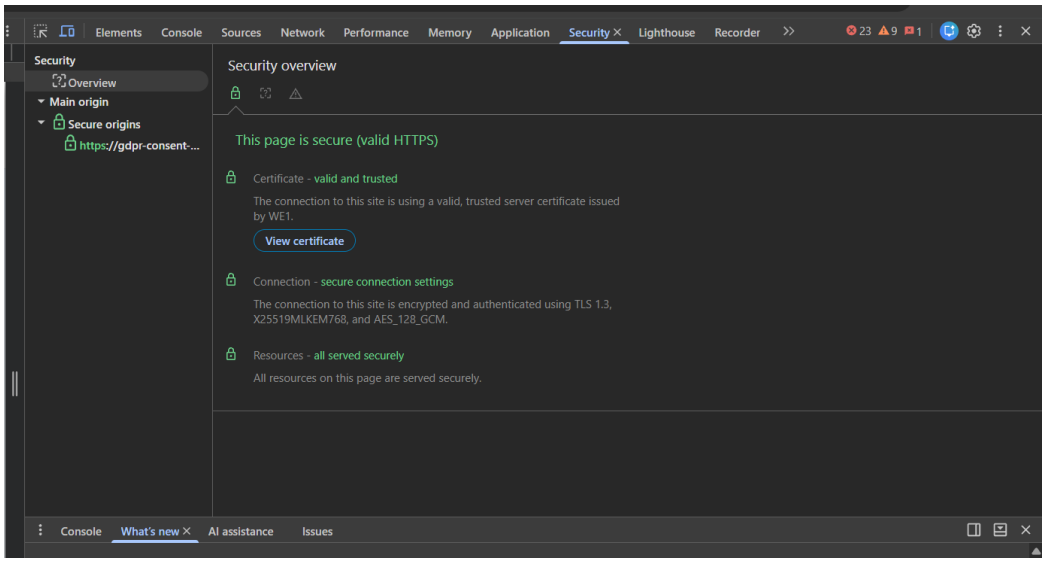
Expected: Plain HTTP redirected to HTTPS or rejected; TLS negotiated at TLS 1.3/1.2; insecure ciphers blocked.

Actual: PASS - production mode answers plain HTTP with 308 to HTTPS and sends HSTS; the deployed site uses TLS 1.3 (X25519MLKEM768, AES_128_GCM) with a valid certificate.

- Production-mode API (NODE_ENV=production) on port 4002: plain request -> HTTP 308 Permanent Redirect, Location: https://localhost:4002/api/v1/health
- Request marked as HTTPS by the proxy (X-Forwarded-Proto: https) -> 200 with Strict-Transport-Security: max-age=31536000; includeSubDomains and the Helmet headers
- Deployed site https://gdpr-consent-manager.onrender.com (Chrome DevTools > Security): valid trusted certificate; TLS 1.3, X25519MLKEM768, AES_128_GCM



TC-SEC-05: sec05 connection secure



TC-SEC-05: sec05 tls13

TC-SEC-06 - Ledger Immutability Enforcement (Security - Mapped to SEC-6)

Expected: Both statements fail with 'permission denied' or trigger exception; ledger completely immutable.

Actual: PASS - UPDATE/DELETE on consent_records and audit_entries rejected by triggers; a superuser bypass is detected by Verify integrity (HASH_MISMATCH).

- UPDATE consent_records -> ERROR: APPEND_ONLY: UPDATE on table consent_records is not allowed
- DELETE consent_records -> ERROR: APPEND_ONLY: DELETE on table consent_records is not allowed
- DELETE audit_entries -> ERROR: APPEND_ONLY: DELETE on table audit_entries is not allowed
- Extra: superuser disabled the trigger and edited one row -> GET /audit/verify: {"ok": false, "checkedAt": "2026-11-03T04:00:04.976Z", "audit": {"ok": true, "checked": 37, "firstBrokenId": null, "reason": null}, "consents": {"ok": false, "checked": 1, "firstBrokenId": "1", "reason": "HASH_MISMATCH"}}

- After reverting the row -> verify: {"ok": true, "checkedAt": "2026-11-03T04:00:05.063Z", "audit": {"ok": true, "checked": 38, "firstBrokenId": null, "reason": null}, "consents": {"ok": true, "checked": 8, "firstBrokenId": null, "reason

DPO CONSOLE · READ-ONLY

Consent records and audit trail

Every consent decision and every security-relevant action, exactly as stored. Records are append-only and hash-chained, so nothing here can be edited or deleted.

Verify integrity

All records intact - no tampering found
Audit trail: 72 checked, chain intact
Consent records: 12 checked, chain intact
Checked Nov 3, 2026, 9:32:49 AM

Consent records | Audit trail | Time travel

Actor (name or e-mail) | Action (LOGIN_FAILED) | Outcome (Any) | From (mm/dd/yyyy) | To (mm/dd/yyyy) | Search

#	TIME	ACTOR	ACTION	TARGET	OUTCOME	HASH
73	Nov 3, 2026, 9:32:44 AM	Meera DPO dpo@demo.com	LOGIN_SUCCEEDED	User	Success	e9bf51386b...
72	Nov 3, 2026, 9:32:42 AM	Ravi Admin admin@demo.com	LOGGED_OUT	User	Success	a8c3616f66...
71	Nov 3, 2026, 9:32:37 AM	Ravi Admin admin@demo.com	LOGIN_SUCCEEDED	User	Success	b42a9ad398...
70	Nov 3, 2026, 9:32:36 AM	Asha User user@demo.com	LOGGED_OUT	User	Success	3b21c29bcf...
69	Nov 3, 2026, 9:32:29 AM	Asha User user@demo.com	LOGIN_SUCCEEDED	User	Success	a6fe4a0050...
68	Nov 3, 2026, 9:32:24 AM	Usability Tester ux@example.com	LOGGED_OUT	User	Success	3fe2ad461a...
67	Nov 3, 2026, 9:32:23 AM	Usability Tester ux@example.com	CONSENT_GRANTED	ProcessingPurpose	Success	e60381ca45...
66	Nov 3, 2026, 9:32:22 AM	Usability Tester ux@example.com	USER_REGISTERED	User	Success	b8aa0b9947...
65	Nov 3, 2026, 9:32:20 AM	Asha User user@demo.com	LOGGED_OUT	User	Success	bf4a679b9c...
64	Nov 3, 2026, 9:32:16 AM	Asha User user@demo.com	CONSENT_WITHDRAWN	ProcessingPurpose	Success	f2c1e341dd...
63	Nov 3, 2026, 9:32:13 AM	Asha User user@demo.com	LOGIN_SUCCEEDED	User	Success	7bfd98b03c...
62	Nov 3, 2026, 9:32:08 AM	Asha User user@demo.com	LOGGED_OUT	User	Success	67acdd8fcb...
61	Nov 3, 2026, 9:32:07 AM	Asha User user@demo.com	LOGIN_SUCCEEDED	User	Success	c21bf27454...
60	Nov 3, 2026, 9:32:06 AM	Meera DPO dpo@demo.com	LOGGED_OUT	User	Success	c7a07e5196...
59	Nov 3, 2026, 9:32:04 AM	Meera DPO dpo@demo.com	LOGIN_SUCCEEDED	User	Success	3317099dc1...
58	Nov 3, 2026, 9:32:03 AM	Ravi Admin admin@demo.com	LOGGED_OUT	User	Success	13c59e4255...
57	Nov 3, 2026, 9:32:02 AM	Ravi Admin admin@demo.com	LOGIN_SUCCEEDED	User	Success	6600984004...
56	Nov 3, 2026, 9:32:00 AM	Asha User user@demo.com	LOGGED_OUT	User	Success	7cfe9b2644...
55	Nov 3, 2026, 9:31:59 AM	Asha User user@demo.com	LOGIN_SUCCEEDED	User	Success	3c54235d00...
54	Nov 3, 2026, 9:31:14 AM	Anonymous	LOGIN_FAILED	User	Failure	9406348ca9...
53	Nov 3, 2026, 9:31:11 AM	Asha User user@demo.com	LOGGED_OUT	User	Success	496450aa9f...
52	Nov 3, 2026, 9:31:07 AM	Asha User user@demo.com	CONSENT_WITHDRAWN	ProcessingPurpose	Success	32f443561a...
51	Nov 3, 2026, 9:31:04 AM	Asha User user@demo.com	LOGIN_SUCCEEDED	User	Success	d0e87d24e7...
50	Nov 3, 2026, 9:31:00 AM	Asha User user@demo.com	LOGGED_OUT	User	Success	d5024534f1...
49	Nov 3, 2026, 9:30:59 AM	Asha User user@demo.com	LOGIN_SUCCEEDED	User	Success	7e2d8d6375...
48	Nov 3, 2026, 9:30:57 AM	Meera DPO dpo@demo.com	LOGGED_OUT	User	Success	2ced8db784...
47	Nov 3, 2026, 9:30:56 AM	Meera DPO dpo@demo.com	LOGIN_SUCCEEDED	User	Success	56181e8744...
46	Nov 3, 2026, 9:30:54 AM	Ravi Admin admin@demo.com	LOGGED_OUT	User	Success	0b44814d2a...
45	Nov 3, 2026, 9:30:53 AM	Ravi Admin admin@demo.com	LOGIN_SUCCEEDED	User	Success	2a2a8429b7...
44	Nov 3, 2026, 9:30:51 AM	Asha User user@demo.com	LOGGED_OUT	User	Success	d6a7d4f431...
43	Nov 3, 2026, 9:30:50 AM	Asha User user@demo.com	LOGIN_SUCCEEDED	User	Success	9b54955f50...
42	Nov 3, 2026, 9:30:07 AM	Asha User user@demo.com	CONSENT_GRANTED	ProcessingPurpose	Success	bd4690fb7b...
		Ravi Admin				

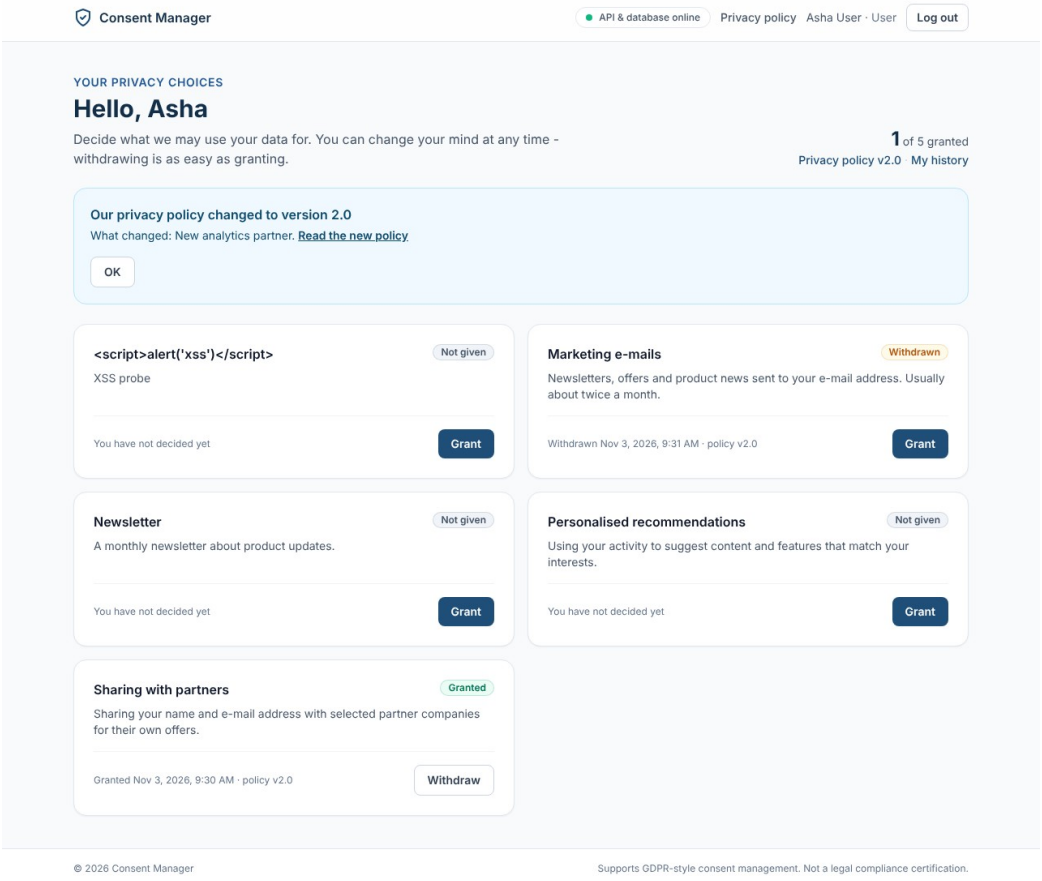
TC-SEC-06: sec06 verify ok

TC-SEC-07 - Input Validation & OWASP Attack Defense (Security - Mapped to SEC-7)

Expected: SQLi safely escaped via parameterized queries; XSS sanitized / HTML-encoded; no script execution.

Actual: PASS - SQLi payloads treated as data (400 / 0 rows); <script> name stored and shown as literal text, no script ran; cross-site POST blocked (403).

- Login with SQLi payload -> HTTP 400 {"error":{"code":"VALIDATION_ERROR","message":"Request validation failed","details":{"email":["Enter a valid e-mail addr
- DPO search user="' OR '1'='1" -> HTTP 200, 0 rows (treated as text)
- Purpose name <script>...: API HTTP 201; stored as literal text: <script>alert('xss')</script>; rendered as text in the UI, no script ran (see UI evidence)
- Cross-site POST with Origin https://evil.example -> HTTP 403 (CSRF check)
- users table intact: 8 rows
- Purpose named <script>alert('xss')</script> rendered as literal text on the dashboard: True; JavaScript dialogs opened: 0



TC-SEC-07: pol04 banner dashboard

TC-SEC-08 - Encryption at Rest for Data & Backups (Security - Mapped to NFR-10)

Expected: Data encrypted using AES-256; emails and credentials unreadable in raw disk inspection.

Actual: PASS (changed method) - all e-mails AES-256-GCM encrypted; pg_dump and app backup contain no plaintext e-mail; passwords only as bcrypt; Neon encrypts storage at rest.

- users.email encrypted (AES-256-GCM, enc:v1) : 8 of 8 rows
- pg_dump of the database: lines containing a plaintext e-mail address = 0
- Passwords stored only as bcrypt hashes.
- Disk/tablespace level: production database on Neon, which encrypts storage and backups at rest with AES-256 (provider-managed).

TC-PERF-01 - Consent Action Latency ≤ 2 Seconds (Performance - Mapped to NFR-1)

Expected: At least 95% of consent actions complete within 2 s with 50 concurrent users; status badge updated.

Actual: PASS - 50 concurrent users, 1 min, 1,253 consent actions: p95 491 ms, 0 % errors.

- k6 consent-actions.js: 50 VUs, 1 min; checks 100 % (2,556/2,556); http_req_failed 0 % (0/2,606)
- consent_action p95 491 ms, max 1.22 s; dashboard p95 251 ms

TC-PERF-02 - DPO Search / Filter Latency ≤ 3 Seconds (Performance - Mapped to NFR-2)

Expected: At least 95% of queries return the first page (50 rows) within 3 s.

Actual: PASS - 10 DPO sessions, 1 min, 550 searches: p95 42 ms, 0 % errors.

- k6 dpo-search.js: 10 VUs, 1 min; checks 100 % (1,110/1,110); http_req_failed 0 % (0/560)
- search p95 42 ms, max 82 ms

TC-SCAL-01 - 50 Concurrent Users & 500k Records (Scalability - Mapped to NFR-3)

Expected: No HTTP 5xx errors; NFR-1 and NFR-2 targets still met with 50 concurrent users, 10,000 users and 500,000 consent records.

Actual: PASS - 10,059 users / 517,306+ records, 50 users + 10 DPO sessions for 10 min: consent p95 1171 ms, search p95 786 ms, 0 HTTP 5xx, 0 % failed. Defect D-03 found on the first run and fixed.

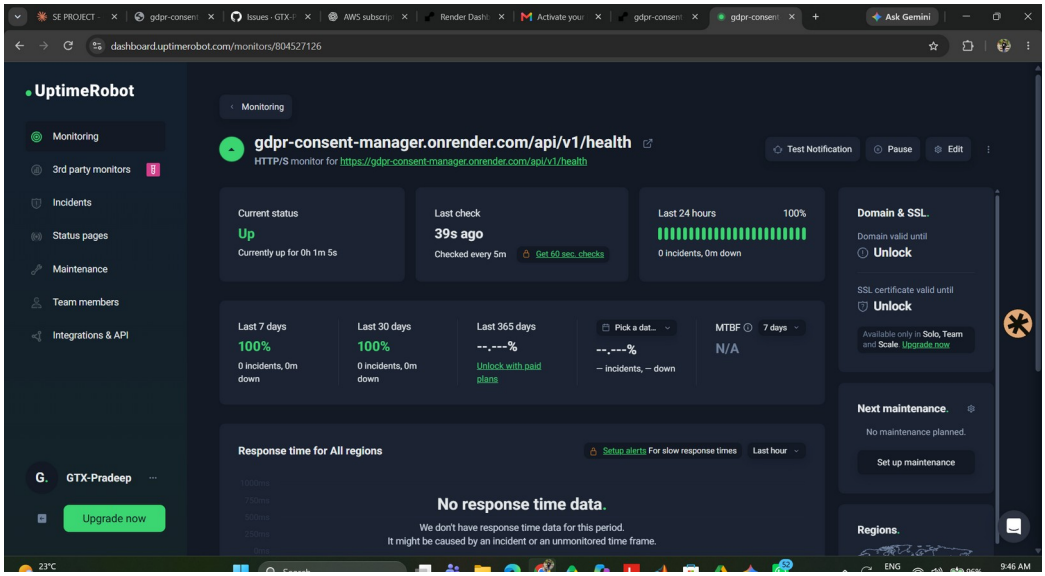
- Volume database: 10,059 users, 517,306 consent records before the run, 528,731 after (records inserted by SQL with synthetic hashes)
- Run 1 (before fix): 1 consent action of 14,786 returned 500 and 25 login audit entries were not written (transaction timeout) -> defect D-03
- Run 2 (after fix): 11,425 consent iterations, 3,740 searches; checks 100 %; http_req_failed 0 %; 0 audit write errors; 0 HTTP 5xx in the server log
- Consent p95 1171 ms, dashboard p95 942 ms, search p95 786 ms

TC-REL-01 - 99% System Operational Uptime (Availability - Mapped to NFR-4)

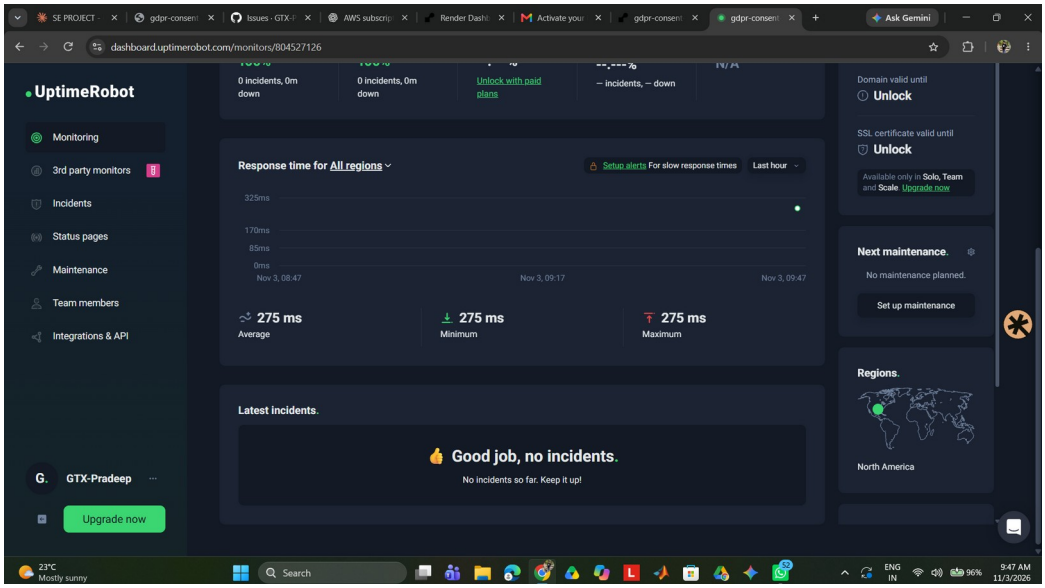
Expected: Availability is at least 99% of scheduled demo/evaluation hours in the month.

Actual: PASS - UptimeRobot monitor on the deployed /api/v1/health every 5 min: Up, 100 % (0 incidents) since deployment on 03-11-2026; local 1-s probe during the load tests: 1,446 of 1,459 checks OK (99.1 %), the misses were only during the 60-user login bursts.

- UptimeRobot: current status Up, last 24 h 100 %, 0 incidents, average response 275 ms (screenshots)
- Local probe file health logs: run during all load tests



TC-REL-01: rel01 uptimerobot



TC-REL-01: rel01 uptimerobot response

TC-REL-02 - Transactional Atomicity of Consent & Audit (Reliability - Mapped to NFR-5)

Expected: Transaction rolls back completely; zero orphaned consent records inserted; HTTP 500 returned.

Actual: PASS - forced audit failure gives HTTP 500 and zero orphan consent rows; works again once the fault is removed.

- Temporary trigger makes every INSERT into audit_entries fail
- GRANT THIRD_PARTY_SHARING -> HTTP 500 {"error":{"code":"INTERNAL_ERROR","message":"Something went wrong","requestId":"db8c3720-2e26-4476-bf7b-fd9d5b6d1a20"}}
- consent_records before/after: 8 / 8 (no orphan row)
- Trigger removed, same request -> HTTP 201

TC-REL-03 - Daily Backup & Restore within RTO (4 Hours) (Recovery - Mapped to NFR-11)

Expected: Database restored cleanly; 100% record integrity verified; restore completes within 4 hours (RTO).

Actual: PASS - backup of 5,377 rows in 0.9 s, restored into an empty database in 2.4 s (RTO 4 h); row counts identical; Verify integrity on the restored copy: both hash chains intact.

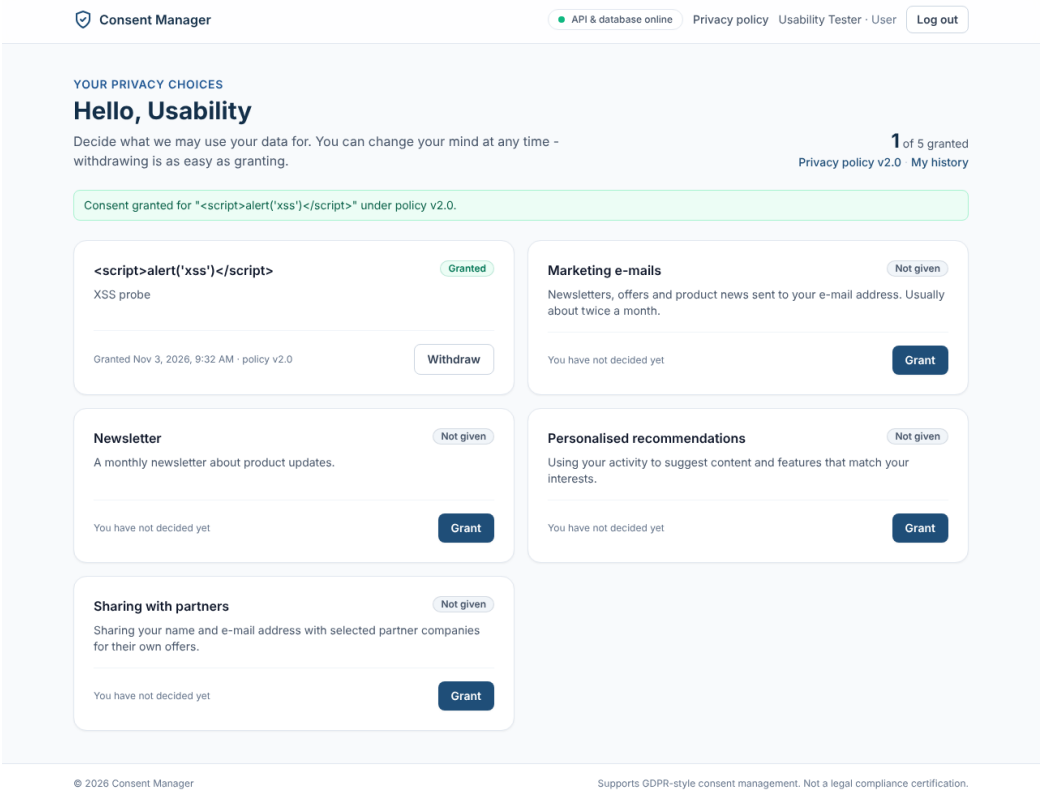
- Backup: {"ms":886,"counts":{"users":59,"processingPurposes":6,"policyVersions":3,"consentRecords":2521,"auditEntries":2784,"policyReviewNotices":4}}
- Restore: {"ms": 2405, "restored": {"users": 59, "processingPurposes": 6, "policyVersions": 3, "consentRecords": 2521, "auditEntries": 2784, "policyReviewNotices": 4}, "verify": {"ok": true, "checkedAt": "2026-11-03T04:13:17.774Z", "audit": {"ok": true, "checked": 2784, "firstBrokenId": null, "reason": null}, "consents": {"ok": true, "checked": 2521, "firstBrokenId": null, "reason": null}}}
- Row counts (table, original, restored): users 59 59; processing_purposes 6 6; policy_versions 3 3; consent_records 2521 2521; audit_entries 2784 2784; policy_review_notices 4 4
- md5 of the consent hash chain is identical in both databases
- Backup file contains 0 plaintext e-mail addresses (encrypted field)

TC-UX-01 - Consent Grant in ≤ 1 Min and ≤ 3 Clicks (Usability - Mapped to NFR-6)

Expected: Completed in 22 seconds and exactly 3 clicks; user confirmed clear understanding.

Actual: PASS - 1 click (Grant) from the dashboard, status Granted in under 1 s; login lands on the dashboard. Participant timings: see Accessibility & Usability Report.

- Scripted journey from the dashboard: 1 click(s) on 'Grant' -> status 'Granted' in 0.75 s (login lands directly on the dashboard)
- Human participant timings are recorded in docs/06-Quality/Accessibility_and_Usability_Report.md (section 3).



TC-UX-01: ux01 granted

TC-UX-02 - WCAG 2.1 AA Keyboard & Contrast Audit (Accessibility - Mapped to NFR-7)

Expected: All controls reachable via keyboard; contrast ratio ≥ 4.6:1; Lighthouse accessibility score ≥ 95.

Actual: PASS - axe-core WCAG 2.1 A/AA scan of 8 pages: 0 violations (incl. colour contrast); keyboard-only login and grant work with a visible focus ring.

- axe-core on 'Log in': 0 violations, 24 rules passed
- axe-core on 'Register': 0 violations, 25 rules passed
- axe-core on 'Consent dashboard': 0 violations, 23 rules passed
- axe-core on 'History': 0 violations, 23 rules passed
- axe-core on 'Privacy policy': 0 violations, 21 rules passed
- axe-core on 'Admin policies': 0 violations, 22 rules passed
- axe-core on 'Admin users': 0 violations, 25 rules passed
- axe-core on 'DPO console': 0 violations, 27 rules passed
- Tab order reached the e-mail field after 4 Tab presses (A: -> A: -> A: -> INPUT:email); visible focus indicator: True
- Full keyboard-only walk-through (login, grant, withdraw with confirm, history, logout) recorded in the Accessibility report (issue #24).

TC-DATA-01 - Retention Policy Compliance (Data Retention - Mapped to NFR-8)

Expected: Records within retention window preserved immutably; no premature truncation.

Actual: PASS - no delete or purge path exists; DELETE blocked by triggers; oldest records still present; retention helper tested.

- No delete/purge job exists in the code base; DELETE is rejected by triggers on consent_records and audit_entries (see TC-SEC-06).
- Oldest consent record still present: 2026-11-03 03:59:52.632+00 | 9
- Retention period configured as RETENTION_YEARS (default 3); retention helper unit tests pass (lib/retention.test.ts).
- Backup script reports how many records are older than the period without deleting anything.

TC-DATA-02 - NTP UTC Synchronization Verification (Data Accuracy - Mapped to NFR-13)

Expected: Clock offset < 20ms; all stored database timestamps in UTC (+00:00).

Actual: PASS - every timestamp column is timestamptz (0 naive); all API times are UTC 'Z'. Host clocks are NTP-synchronised by Render/Neon.

- DB TimeZone | timestamptz columns | naive timestamp columns: Etc/UTC | 10 | 0
- API /health time 2026-11-03T04:00:07.261Z vs client clock 2026-11-03T04:00:07.262461+00:00 -> offset 1 ms
- All API timestamps are ISO-8601 with 'Z' (UTC).
- NTP: host clocks are synchronised by the hosting providers (Render, Neon); no NTP container is run by the app.

TC-PRIV-01 - Data Minimization Audit (Privacy - Mapped to NFR-9)

Expected: Only name, email, password hash, role, consent actions, and audit data stored; no sensitive/special category data.

Actual: PASS - only name, encrypted e-mail, password hash, role/account state, consents, policies and audit data are stored.

- All columns:
- audit_entries(id, actor_id, action, target_type, target_id, outcome, details, created_at, prev_hash, hash)
- consent_records(id, user_id, purpose_id, action, policy_version_id, recorded_at, prev_hash, hash)
- policy_review_notices(id, user_id, policy_version_id, created_at, acknowledged_at)
- policy_versions(id, version_no, title, body, change_summary, status, effective_at, created_by_id, created_at)
- processing_purposes(id, code, name, description, is_active, created_at, updated_at)
- users(id, name, email, password_hash, role, is_active, failed_login_count, locked_until, created_at, session_version, email_hash)

TC-MAINT-01 - Layered Architecture & ≥70% Test Coverage (Maintainability - Mapped to NFR-12)

Expected: CI report shows passing tests and at least 70% service-layer coverage; clear separation of UI, API, Service, DAO.

Actual: PASS - 225 automated tests pass in CI; service-layer statement coverage 94.8 % (target 70 %); layers: React UI -> API routes -> services -> Prisma (DAO) -> PostgreSQL.

- Server: 17 test files, 172 tests; statements 95.67 %, branches 88.51 %
- Client: 8 test files, 53 tests; statements 89.24 %, branches 85.34 %
- Service files (*.service.ts): statements 94.8 %, branches 87.7 %
- GitHub Actions workflow ci.yml runs lint, type-check, tests and build on every pull request

TC-RTM-01 - Requirements Traceability Verification (Traceability - Mapped to NFR-14)

Expected: 100% bidirectional traceability confirmed; zero orphaned requirements or untraceable test cases.

Actual: PASS - 41 requirements (20 FR, 7 SEC, 14 NFR) each map to exactly one test case, and all 41 test cases map back to a requirement: 100 % bidirectional, no orphans.

- RTM table in the Test Plan: 41 rows (FR-1..FR-20, SEC-1..SEC-7, NFR-1..NFR-14), each with one test case; 41 distinct test case IDs; every test case section header names its requirement